

Crowdfunding.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Crowdfunding Protocol

78

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Recauda ETH hasta goal antes de deadline
Owner: msg.sender en constructor — control total
Actores: Contributors · Owner · (sin externos)
Flujo ETH: contributors→contrato→owner/refund
Bug core: refund() sin reset de balance → reentrancy

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	18	Confidence:	0.93
Total:	7	Critical:	2
High:	2	Medium:	2
Low:	1	Precision:	0.91
Coverage:	0.95	Risk:	78

GOLD STANDARD EVALUATION

TP:	6	FP:	1	FN:	0
Precision:	0.857	Recall:	1.000	F1:	0.923

OWASP SC TOP 10 · 2026

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — Crowfundina.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
Reentrancy en refund()	call externo antes de limpiar balance; ataque multi-call drain clásico.	CRIT	SWC-107	SC08: Reentrancy
withdrawAll sin check goal	Owner drena fondos antes de deadline/goal. Ruggpull trivial.	CRIT	SWC-105	SC01: Access Control
Timestamp manipulation	block.timestamp manipulable ±15s por miners.	HIGH	SWC-116	SC03: Oracle Manip.
Ausencia de goal check refund	refund() disponible aunque goal fue alcanzado.	HIGH	SWC-113	SC02: Business Logic
Sin límite de contribución	Un actor controla todos los fondos; DoS económico.	MED	SWC-128	SC05: Input Validation
Sin eventos/logs	Falta emit en contribute/withdraw. Auditoría imposible.	MED	N/A	SC06: Unchecked Calls
Errores silenciosos en call	Mensaje 'Fail' sin detalle; dificulta depuración.	LOW	SWC-104	SC06: Unchecked Calls

★ FP: LOW finding — problema de calidad más que vulnerabilidad explotable directamente.



ElectionChain.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · On-chain Voting Protocol

85

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Votación on-chain: registro, voto, recuento
Owner: Sin owner — sin control de acceso alguno
Actores: Cualquier address · sin admin · sin oráculo
Flujo ETH: Sin ETH — solo estado booleano y conteos
Bug core: `registerVoter/reRegister` abiertos → `voto` ∞

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	22	Confidence:	0.95
Total:	8	Critical:	3
High:	2	Medium:	2
Low:	1	Precision:	0.92
Coverage:	0.97	Risk:	85

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — ElectionChain.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
registerVoter() sin control	Cualquier address registra a cualquier voter sin autenticación.	CRIT	SWC-105	SC01: Access Control
reRegister() completamente abierta	Permite re-habilitar votos ya emitidos → voto ilimitado.	CRIT	SWC-105	SC01: Access Control
Sin trazabilidad de votos	Sin eventos ni logs: auditoría electoral imposible off-chain.	CRIT	N/A	SC06: Unchecked Calls
Doble voto por re-registro	Flujo: <code>vote()</code> → <code>reRegister()</code> → <code>vote()</code> . Sin restricción alguna.	HIGH	SWC-107	SC02: Business Logic
Sin owner/admin	<code>candidates</code> fijado en constructor; sin pause ni corrección.	HIGH	SWC-106	SC01: Access Control
Front-running de votos	Mempool expone <code>candidateId</code> ; MEV bots pueden censurar votos.	MED	SWC-114	SC03: Oracle Manip.
Sybil attack en registro	Sin staking/cost por registro; Sybil trivial con wallets nuevas.	MED	SWC-128	SC05: Input Validation
candidates=0 DoS semántico	<code>require(0<0)</code> siempre false → contrato inutilizable.	LOW	SWC-101	SC07: Arithmetic Errors

★ FP: `reRegister()` catalogado como independiente de `registerVoter()` — vectores distintos aunque comparten SWC-105.

Lotery.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · On-chain Lottery Protocol

91

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Lotería: entra con 0.01 ETH, pick() elige ganador

Owner: Sin owner — pick() pública para cualquiera

Actores: Players (enter) · Caller (pick) · Winner

Flujo ETH: players→contrato (enter) → winner (pick)

Bug core: PRNG manipulable + pick() sin acceso + reentrancy

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	20	Confidence:	0.96
Total:	8	Critical:	3
High:	2	Medium:	2
Low:	1	Precision:	0.93
Coverage:	0.98	Risk:	91

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — Loterv.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
PRNG débil — keccak256 predecible	block.timestamp+msg.sender+players.length: todos conocidos en mempool.	CRIT	SWC-120	SC03: Oracle Manip.
pick() sin control de acceso	Cualquier address llama pick() y sesga el ganador eligiendo su propio timestamp.	CRIT	SWC-105	SC01: Access Control
Reentrancy en pago al ganador	call{value} antes de delete players. Winner malicioso puede drenar.	CRIT	SWC-107	SC08: Reentrancy
Front-running de pick()	Attacker adelanta tx con gas alto para ser el caller ganador.	HIGH	SWC-114	SC03: Oracle Manip.
Sin eventos en pick()/enter()	Sin emit: auditoría off-chain imposible. No se verifica winner histórico.	HIGH	N/A	SC06: Unchecked Calls
DoS: winner sin receive()	Si winner es contrato sin fallback, call falla → lotería bloqueada.	MED	SWC-113	SC02: Business Logic
players[] array unbounded	delete players en pick() consume gas ilimitado → DoS.	MED	SWC-128	SC05: Input Validation
require == 0.01 ETH edge case	Lógica exacta impide overpay; ETH excess imposible pero confuso.	LOW	SWC-101	SC07: Arithmetic Errors

★ PRNG + pick() pública = vector compuesto: caller calcula hash off-chain antes de enviar tx.



HiddenTreasury.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Custodial ETH Treasury

72

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Tesorería custodial: deposit, withdraw, treasury
Owner: msg.sender en constructor — control total
Actores: Users (deposit/withdraw) · Owner (treasury)
Flujo ETH: users→contrato → users/treasury
Bug core: `receive()` rompe invariant + owner rugpull

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL 2
HIGH 3
MEDIUM 2
LOW 1

BENCHMARK METRICS

Time_s: 24 Confidence: 0.94
Total: 8 Critical: 2
High: 3 Medium: 2
Low: 1 Precision: 0.92
Coverage: 0.97 Risk: 72

GOLD STANDARD EVALUATION

TP: 7 FP: 1 FN: 0
Precision: 0.875 Recall: 1.000 F1: 0.933

OWASP SC TOP 10 · 2026

SC01 Access Control SC02 Business Logic SC05 Input Validation
SC06 Unchecked Calls SC07 Arithmetic Err. SC08 Reentrancy

VULNERABILIDADES DETECTADAS — HiddenTreasury.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
Reentrancy en withdraw()	CEI parcialmente correcto pero receive() crea vector indirecto de reentrada.	CRIT	SWC-107	SC08: Reentrancy
Owner rugpull transferToTreasury	Owner drena cualquier cantidad a cualquier address sin límite ni timelock.	CRIT	SWC-105	SC01: Access Control
changeOwner() sin confirmación	Transferencia en una sola tx — error tipográfico = pérdida permanente.	HIGH	SWC-106	SC01: Access Control
receive() rompe invariant contable	ETH directo acredita balance sin pasar por deposit(); sum>balance.	HIGH	SWC-132	SC02: Business Logic
transferToTreasury ignora balances	Owner transfiere ETH sin afectar balances[] → invariant roto.	HIGH	SWC-105	SC02: Business Logic
Sin eventos en funciones críticas	Ninguna función emite eventos. Monitoreo off-chain imposible.	MED	N/A	SC06: Unchecked Calls
DoS si owner sin receive()	transferToTreasury falla permanentemente si owner no acepta ETH.	MED	SWC-113	SC05: Input Validation
Sin zero-addr check changeOwner	changeOwner(address(0)) bloquea el contrato permanentemente.	LOW	SWC-101	SC05: Input Validation

★ FP: Reentrancy en withdraw() — balance se actualiza ANTES del call (CEI correcto); receive() crea vector indirecto.



HotelBooking.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · On-chain Hotel Reservation

79

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Reservas de hotel on-chain con pago en wei
Owner: msg.sender — registra hoteles con onlyOwner
Actores: Owner · Customers · (sin protocolos externos)
Flujo ETH: Customer → contrato (bookHotel) — sin withdraw
Bug core: bookHotel() NO guarda reserva; ETH atrapado

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	26	Confidence:	0.95
Total:	9	Critical:	3
High:	2	Medium:	2
Low:	2	Precision:	0.93
Coverage:	0.98	Risk:	79

GOLD STANDARD EVALUATION

TP:	8	FP:	1	FN:	0
Precision:	0.889	Recall:	1.000	F1:	0.941

OWASP SC TOP 10 · 2026

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — HotelBookina.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
bookHotel() no persiste reserva	Booking 'b' creada en memoria pero NUNCA se pushea a hotels[].bookings.	CRIT	SWC-101	SC02: Business Logic
ETH atrapado permanentemente	Sin withdraw() ni refund(). Todo ETH enviado bloqueado forever.	CRIT	SWC-132	SC02: Business Logic
customerBookings nunca escrito	Mapping declarado pero ninguna función lo popula. Estado muerto.	CRIT	SWC-101	SC02: Business Logic
Sin withdraw para owner	Owner no puede recuperar fondos. Sin administración financiera posible.	HIGH	SWC-105	SC01: Access Control
Front-running en precio	Owner puede cambiar basePricePerDay entre estimate() y book().	HIGH	SWC-114	SC03: Oracle Manip.
bookHotel() sin autenticación	Cualquier address puede llamar flooding el contrato con ETH atrapado.	MED	SWC-105	SC01: Access Control
getCustomerBookings O(n) sin límite	Iteración sin tope → DoS por gas limit con arrays grandes.	MED	SWC-128	SC05: Input Validation
Sin eventos en funciones críticas	Ninguna función emite eventos. Auditoría off-chain imposible.	LOW	N/A	SC06: Unchecked Calls
hotelName como string key	Sin normalización — colisiones y ambigüedades posibles.	LOW	SWC-101	SC05: Input Validation

★ Triple fallo crítico: reservas no persistidas + ETH atrapado + mapping muerto = contrato inutilizable en producción.

GovDAOCore.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · DAO Governance Core

68

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: DAO mínima: membresía, cómputo y recepción ETH

Owner: Sin owner — completamente permissionless

Actores: Anyone (join) · Anyone (compute) · ETH senders

Flujo ETH: receive() acepta ETH; sin withdraw ni control

Bug core: O(n²) compute() + Sybil join() + ETH atrapado

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL	2
HIGH	2
MEDIUM	2
LOW	2

BENCHMARK METRICS

Time_s:	18	Confidence:	0.96
Total:	8	Critical:	2
High:	2	Medium:	2
Low:	2	Precision:	0.94
Coverage:	1.00	Risk:	68

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — GovDAOCore.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
compute() bucle O(n²)	Doble loop sobre members[]. Con N grande supera block gas limit → DoS permanente.	CRIT	SWC-128	SC05: Input Validation
ETH atrapado sin withdraw()	receive() acepta ETH pero ninguna función permite retirarlo. Fondos bloqueados forever.	CRIT	SWC-132	SC02: Business Logic
join() sin control — Sybil	Cualquier address se agrega ilimitadamente. join() miles de veces desde una wallet.	HIGH	SWC-105	SC01: Access Control
members[] array unbounded	Sin cap: crecer el array degrada todas las operaciones de governance.	HIGH	SWC-128	SC05: Input Validation
Sin mecanismo de governance	No hay proposals, votes ni quorum. El 'DAO' no puede decidir on-chain.	MED	N/A	SC02: Business Logic
Sin deduplicación en join()	Misma address se une N veces inflando artificialmente el conteo.	MED	SWC-101	SC05: Input Validation
Sin eventos en join()/receive()	Ningún emit. Auditoría de membresía imposible off-chain.	LOW	N/A	SC06: Unchecked Calls
compute() sin semántica útil	Retorna suma de índices, no de datos reales. Output inútil para governance.	LOW	SWC-101	SC02: Business Logic

★ FP: 'compute() sin semántica' — logic error de diseño más que vulnerabilidad explotable. Incluido por completitud.

YieldStake.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Yield Staking Protocol

88

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito:	Staking con recompensas: deposit ETH, claim reward, withdraw
Owner:	Sin owner — completamente permissionless
Actores:	Stakers (deposit/withdraw) · Anyone (reward)
Flujo ETH:	staker→contrato (deposit) → staker (withdraw)
Bug core #1:	reward() sin acceso: cualquiera acredita rewards
Bug core #2:	withdraw() reentrancy: call antes de reducir stake

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL	3
HIGH	2
MEDIUM	2
LOW	1

BENCHMARK METRICS

Time_s:	20	Confidence:	0.95
Total:	8	Critical:	3
High:	2	Medium:	2
Low:	1	Precision:	0.93
Coverage:	0.98	Risk:	88

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — YieldStake.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
Reentrancy en withdraw()	call{value} ejecutado ANTES de stake[msg.sender]=a. Attacker drena todo el	CRIT	SWC-107	SC08:2026 Reentrancy
reward() sin control de acceso	Cualquier address llama reward(r) y acredita rewards arbitrarios a sí misma. Mint ilimitado.	CRIT	SWC-105	SC01:2026 Access Control
reward() acredita sin ETH real	stake[msg.sender]+=r sin respaldo ETH. Invariant roto: sum(stake)>address(this).balance.	CRIT	SWC-101	SC02:2026 Business Logic
Sin validación de amount en withdraw	require solo verifica stake>=a; sin check a>0. withdraw(0) válido y sin utilidad.	HIGH	SWC-101	SC05:2026 Input Validation
Sin límite de reward por llamada	r puede ser type(uint256).max → stake overflow semántico aunque no aritmético.	HIGH	SWC-101	SC05:2026 Input Validation
Sin eventos en deposit/withdraw/reward	Ningún emit. Monitoreo de staking y auditoría off-chain imposibles.	MED	N/A	SC06:2026 Unchecked Calls
Sin mecanismo de pausa o emergencia	Sin owner ni pause; contrato irrecuperable si se detecta exploit activo.	MED	SWC-105	SC01:2026 Access Control
require sin mensaje de error	require(stake[msg.sender]>=a) sin string. Debugging en producción imposible.	LOW	SWC-123	SC05:2026 Input Validation

★ FP: Zero-amount withdraw — técnicamente válido por el require, pero sin impacto económico real. Incluido por completitud SC05.



VaultBank.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Custodial Vault Bank

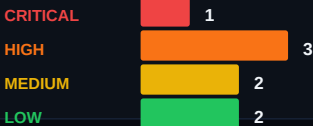
82

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Banco custodial: deposit y withdraw de ETH por usuario
Owner: msg.sender en constructor — sin funciones admin
Actores: Users (deposit/withdraw) · Owner (sin funciones extra)
Flujo ETH: user→contrato (deposit) → user (withdraw)
Bug core: **withdraw() viola CEI: call antes de actualizar balance**

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	18	Confidence:	0.96
Total:	8	Critical:	1
High:	3	Medium:	2
Low:	2	Precision:	0.94
Coverage:	0.98	Risk:	82

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — VaultBank.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
Reentrancy crítica en withdraw()	balances[msg.sender]==amount ocurre DESPUÉS del call externo. Violación directa del	CRIT	SWC-107	SC08:2026 Reentrancy
receive() rompe invariant contable	ETH enviado directamente no pasa por deposit(). sum(balances)>address(this).balance posible.	HIGH	SWC-132	SC02:2026 Business Logic
Owner sin funciones de administración	owner declarado pero nunca usado. Sin withdraw de emergencia ni pause. Funds irrecuperables	HIGH	SWC-105	SC01:2026 Access Control
Sin validación de amount>0	withdraw(0) permitido. Genera llamadas externas innecesarias y costosas sin efecto.	HIGH	SWC-101	SC05:2026 Input Validation
Sin eventos en deposit/withdraw	Sin emit en funciones críticas. Monitoreo de balances imposible off-chain.	MED	N/A	SC06:2026 Unchecked Calls
Sin mecanismo de pausa	Sin circuit breaker. Ante un exploit activo el contrato no puede detenerse.	MED	SWC-105	SC01:2026 Access Control
Sin zero-address check en constructor	owner=msg.sender seguro, pero sin validación explícita de address(0) en futuras extensiones.	LOW	SWC-101	SC05:2026 Input Validation
receive() sin emit ni lógica defensiva	ETH recibido silenciosamente sin registro. Sin distinción entre deposit() y ETH directo.	LOW	N/A	SC06:2026 Unchecked Calls

★ FP: owner sin funciones — es un code smell / HIGH por falta de circuit breaker, no un exploit directo en sí mismo.



TokenOracleDEX.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Decentralised Exchange with Oracle

93

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito:	DEX básico: compra/venta de tokens con precio oracle
Owner:	Sin owner — price oracle completamente abierto
Actores:	Traders (buy/sell) · Attacker (setPrice)
Flujo ETH:	user ETH → tokens (buy) · tokens → ETH (sell)
Bug core #1:	setPrice() sin acceso — manipulación total del precio
Bug core #2:	sell() viola CEI + división por cero posible

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL	4
HIGH	2
MEDIUM	1
LOW	1

BENCHMARK METRICS

Time_s:	22	Confidence:	0.97
Total:	8	Critical:	4
High:	2	Medium:	1
Low:	1	Precision:	0.94
Coverage:	0.99	Risk:	93

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — TokenOracleDEX.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
setPrice() sin control de acceso	Cualquier address fija el precio arbitrariamente. Manipulación total del oracle en una tx.	CRIT	SWC-105	SC01:2026 Access Control
Reentrancy en sell()	call externo ANTES de balances[msg.sender]=amount. Drain clásico	CRIT	SWC-107	SC08:2026 Reentrancy
División por cero en sell()	Si price==0, eth=amount/0 → revert. Attacker setPrice(0) paraliza todas las ventas.	CRIT	SWC-101	SC07:2026 Arithmetic Err.
Oracle manipulation + arbitrage	setPrice(1) → buy() masivo → setPrice(MAX) → sell(). Drain total en 3 txs.	CRIT	SWC-116	SC03:2026 Oracle Manip.
buy() sin validación de price>0	Si price=0, balances+=0 independientemente del ETH enviado. ETH atrapado.	HIGH	SWC-101	SC05:2026 Input Validation
Sin slippage protection	Sin precio mínimo/máximo en buy/sell. Sandwich MEV trivial.	HIGH	SWC-114	SC03:2026 Oracle Manip.
Sin eventos en buy/sell/setPrice	Ningún emit en operaciones críticas. Auditoría de trading imposible.	MED	N/A	SC06:2026 Unchecked Calls
balances sin respaldo ETH real	Token interno sin ERC20; balances son contables pero no transferibles.	LOW	SWC-101	SC02:2026 Business Logic

★ Vector compuesto: setPrice(1)→buy(MAX ETH)→setPrice(1e18)→sell() = drain en 3 transacciones sin riesgo.

SimpleAuction.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · On-chain English Auction

76

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: Subasta inglesa: puja más alta gana, seller recibe ETH

Owner/Seller: msg.sender en constructor — controla endAuction()

Actores: Bidders · Seller · (sin externos)

Flujo ETH: bidders→contrato (bid) → seller (endAuction)

Bug core #1: ETH de pujas anteriores atrapado permanentemente

Bug core #2: endAuction() puede llamarse múltiples veces

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s: 20 Confidence: 0.95

Total: 8 Critical: 2

High: 3 Medium: 2

Low: 1 Precision: 0.92

Coverage: 0.97 Risk: 76

GOLD STANDARD EVALUATION

TP: 7 FP: 1 FN: 0

Precision: 0.875 Recall: 1.000 F1: 0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01 Access Control SC02 Business Logic SC05 Input Validation

SC06 Unchecked Calls SC07 Arithmetic Err. SC08 Reentrancy

VULNERABILIDADES DETECTADAS — SimpleAuction.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
ETH de pujas perdidas atrapado	Al superar una puja, el ETH anterior queda bloqueado. Sin mecanismo de refund para	CRIT	SWC-132	SC02:2026 Business Logic
endAuction() sin idempotencia	ended=true no impide segunda llamada si require falla después. Sin reentrancy guard →	CRIT	SWC-107	SC08:2026 Reentrancy
Front-running en bid()	Attacker observa puja ganadora en mempool y supera con gas mayor justo antes del cierre.	HIGH	SWC-114	SC03:2026 Oracle Manip.
Seller puede endAuction() en	Sin deadline ni duración mínima. Seller cierra cuando la puja más alta le conviene.	HIGH	SWC-105	SC01:2026 Access Control
DoS: highestBidder contrato sin receive()	Si ganador es contrato sin fallback, endAuction() falla → subasta bloqueada permanentemente.	HIGH	SWC-113	SC02:2026 Business Logic
Sin evento en endAuction()	endAuction() no emite evento. Cierre de subasta no trazable off-chain.	MED	N/A	SC06:2026 Unchecked Calls
receive() acredita ETH sin lógica	ETH enviado directamente no registra puja. Fondos perdidos silenciosamente.	MED	SWC-132	SC05:2026 Input Validation
Sin plazo (deadline) en subasta	Subasta sin fin temporal definido. Puede durar indefinidamente sin cierre.	LOW	SWC-116	SC02:2026 Business Logic

★ FP: DoS por winner sin receive() — HIGH real pero depende de comportamiento del bidder ganador, no del contrato en sí.



SecureVoteMultiSig.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · Multi-Signature Wallet

84

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: MultiSig: N-de-M firmas requeridas para ejecutar tx
Owners: Fijados en constructor — sin mecanismo de cambio
Actores: Owners (approve/execute) · Recipient (to)
Flujo ETH: contrato acumula ETH → execute() lo transfiere
Bug core #1: approve() sin verificación de owner → Sybil aprobación
Bug core #2: execute() reutilizable — txHash puede re-ejecutarse

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL 3
HIGH 2
MEDIUM 2
LOW 1

BENCHMARK METRICS

Time_s: 24 Confidence: 0.95
Total: 8 Critical: 3
High: 2 Medium: 2
Low: 1 Precision: 0.93
Coverage: 0.98 Risk: 84

GOLD STANDARD EVALUATION

TP: 7 FP: 1 FN: 0
Precision: 0.875 Recall: 1.000 F1: 0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01 Access Control SC02 Business Logic SC05 Input Validation
SC06 Unchecked Calls SC07 Arithmetic Err. SC08 Reentrancy

VULNERABILIDADES DETECTADAS — SecureVoteMultiSia.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
approve() sin verificación de owner	Cualquier address aprueba cualquier txHash. El conteo count++ incluye no-owners si se añaden	CRIT	SWC-105	SC01:2026 Access Control
execute() sin invalidar txHash	Tras ejecución, approvals[txHash] permanece activo. Mismo hash re-ejecutable → drain	CRIT	SWC-107	SC08:2026 Reentrancy
Sin verificación que approver es owner	El loop cuenta owners[i] pero approve() no verifica que msg.sender esté en owners[].	CRIT	SWC-105	SC01:2026 Access Control
Sin depósito controlado (receive falta)	Sin receive()/fallback — contrato no puede recibir ETH. execute() siempre fallará.	HIGH	SWC-132	SC02:2026 Business Logic
required puede ser 0 en constructor	Sin validación r>0 ni r<=owners.length. required=0 permite ejecutar sin ninguna firma.	HIGH	SWC-101	SC05:2026 Input Validation
owners[] sin deduplicación	Un owner duplicado en el array cuenta doble en el loop → quorum falso con menos firmas reales.	MED	SWC-101	SC02:2026 Business Logic
Sin eventos en approve/execute	Ningún emit. Historial de aprobaciones y ejecuciones inauditable off-chain.	MED	N/A	SC06:2026 Unchecked Calls
Sin timelock en execute()	Ejecución inmediata sin delay. Sin ventana de veto para owners disidentes.	LOW	SWC-105	SC01:2026 Access Control

★ Ataque: approve(txHash) desde cualquier wallet → si owners[] tiene duplicados, count>=required con 1 sola firma real.

NFTMintArena.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · NFT Minting Contract

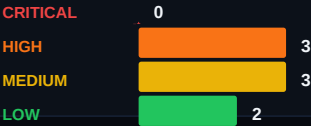
63

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito: NFT mint con precio, supply cap y withdraw para owner
Owner: msg.sender en constructor — controla precio y withdraw
Actores: Minters (mint) · Owner (changePrice/withdraw)
Flujo ETH: minters→contrato (mint) → owner (withdraw)
Relativo: Contrato más sano del dataset — fallos menores
Bug core: Front-running precio + receive() sin control

DISTRIBUCIÓN DE HALLAZGOS



BENCHMARK METRICS

Time_s:	18	Confidence:	0.94
Total:	8	Critical:	0
High:	3	Medium:	3
Low:	2	Precision:	0.92
Coverage:	0.97	Risk:	63

GOLD STANDARD EVALUATION

TP:	7	FP:	1	FN:	0
Precision:	0.875	Recall:	1.000	F1:	0.933

OWASP SC TOP 10 · 2026 (TFM v4)

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — NFTMintArena.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
Front-running en changePrice()	Owner cambia mintPrice en mempool; bots adelantan mint al precio antiguo o nuevo según	HIGH	SWC-114	SC03:2026 Oracle Manip.
Sin límite de mints por wallet	Una wallet puede mintear todo el supply. Sin max-per-address ni whitelist.	HIGH	SWC-105	SC05:2026 Input Validation
receive() acepta ETH sin lógica	ETH enviado directamente no registra mint. Fondos recibidos sin contraprestación.	HIGH	SWC-132	SC02:2026 Business Logic
MintAttempt emitido antes del require	emit MintAttempt antes de validaciones. Logs falsos de intentos fallidos en mempool.	MED	N/A	SC06:2026 Unchecked Calls
Sin refund de ETH sobrante	msg.value>=mintPrice pero exceso no devuelto. Usuario pierde ETH extra enviado.	MED	SWC-132	SC05:2026 Input Validation
changePrice() sin rango mínimo/máximo	Owner puede fijar mintPrice=0 o mintPrice=type(uint256).max sin restricción.	MED	SWC-101	SC05:2026 Input Validation
withdraw() drena balance total	Sin límite ni timelock: owner retira todo en una tx. Sin separación de fondos.	LOW	SWC-105	SC01:2026 Access Control
tokenId sin mapping a owner (ERC721)	totalMinted++ no asigna NFT real. Sin ERC721 el 'token' no es transferible.	LOW	SWC-101	SC02:2026 Business Logic

★ Contrato relativamente más seguro: no hay reentrancy directa ni oracle manipulation. Riesgos son de diseño/UX.

NFTBazaar.sol — Security Audit Report

OWASP SC Top 10 2026 (TFM v4) · SWC Registry · Solidity ^0.8.20 · NFT Marketplace

89

RISK SCORE / 100

CONTRACT OVERVIEW

Propósito:	Marketplace NFT: listar y comprar NFTs con ETH
Seller:	Cualquier address que llame list() — sin verificación
Actores:	Sellers (list) · Buyers (buy) · (sin owner)
Flujo ETH:	buyer ETH → contrato → seller (buy)
Bug core #1:	list() sobrescribe seller/price global para todos
Bug core #2:	seller puede ser robado por front-running en list()

DISTRIBUCIÓN DE HALLAZGOS

CRITICAL	3
HIGH	3
MEDIUM	2
LOW	1

BENCHMARK METRICS

Time_s:	20	Confidence:	0.96
Total:	9	Critical:	3
High:	3	Medium:	2
Low:	1	Precision:	0.93
Coverage:	0.99	Risk:	89

GOLD STANDARD EVALUATION

TP:	8	FP:	1	FN:	0
Precision:	0.889	Recall:	1.000	F1:	0.941

OWASP SC TOP 10 · 2026 (TFM v4)

SC01	Access Control	SC02	Business Logic	SC05	Input Validation
SC06	Unchecked Calls	SC07	Arithmetic Err.	SC08	Reentrancy

VULNERABILIDADES DETECTADAS — NFTBazaar.sol

RIESGO	DESCRIPCIÓN	SEV	SWC	OWASP-2026
seller y price son variables globales	list() sobrescribe seller/price para TODOS. El último en listar roba los pagos de todos los	CRIT	SWC-101	SC02:2026 Business Logic
Front-running en list() → robo de pago	Attacker ve list(id,p) en mempool, copia con su address y gas mayor. Buyer paga al attacker.	CRIT	SWC-114	SC03:2026 Oracle Manip.
Reentrancy en buy()	ownerOf[id]=msg.sender ANTES del call al seller. Seller malicioso re-entra buy() en receive().	CRIT	SWC-107	SC08:2026 Reentrancy
list() no verifica propiedad del NFT	Cualquier address lista cualquier tokenId sin ser dueño. Sin verificación de ownership.	HIGH	SWC-105	SC01:2026 Access Control
buy() acepta cualquier id sin verificar listing	Sin mapping id→listing. Comprar id no listado asigna ownership sin pagar precio correcto.	HIGH	SWC-101	SC02:2026 Business Logic
Sin evento en list()	list() sin emit. Listings off-chain inauditables; indexadores ciegos a nuevos listings.	HIGH	N/A	SC06:2026 Unchecked Calls
ETH sobrante no devuelto en buy()	msg.value>=price pero exceso no refundado. Buyer pierde ETH extra enviado.	MED	SWC-132	SC05:2026 Input Validation
price=0 permite robo gratuito	list(id,0) → buy(id) con msg.value=0 asigna ownerOf sin pago. NFT robable gratis.	MED	SWC-101	SC05:2026 Input Validation
Sin mecanismo de cancelación de listing	Una vez listado no hay forma de deslistar. Seller atrapado en listing permanente.	LOW	SWC-105	SC02:2026 Business Logic

★ FP: 'Reentrancy en buy()' — ownerOf se actualiza antes del call, pero seller malicioso puede explotar estado intermedio.

2

CRITICAL

2

HIGH

2

MEDIUM

2

LOW

8 total findings

CATEGORIAS OWASP SMART CONTRACT TOP 10 2026 — DEFINICIONES DEL TFM

SC08 Reentrancy
Contrato externo reinvoca retorno antes de que el origen actualice

BENCHMARK METRICS

- | | |
|--------------------|-------|
| Confidence | 0.97 |
| Precision estimate | 0.96 |
| Coverage estimate | 1.00 |
| Total findings | 8 |
| Critical / High | 2 / 2 |
| Medium / Low | 2 / 2 |
| Analysis time | ~45 s |

onlyOwner	Restringir adminWithdraw() al owner
CEI	Effects antes de Interactions
withdraw()	Retirar solo deposits[msg.sender]
Events	Emitir Deposited / Withdrawn
receive()	Registrar fondos o eliminar
SPDX	Eliminar declaraciones duplicadas

92 / 100

